

Sistema de Monitoramento e Controle Preparatório para Auditoria de TI

Desenvolvimento da Proposta de Sistema de Monitoramento e Controle

- **Ferramentas e Métodos:**

- *SIEM (Security Information and Event Management)*: Ferramenta para análise centralizada de logs e identificação de atividades anômalas.
- *IDS/IPS (Intrusion Detection/Prevention Systems)*: Detectam e previnem tentativas de intrusão em redes.
- *Scanners de Vulnerabilidade*: Ferramentas como Nessus ou Qualys para identificar vulnerabilidades em sistemas e aplicações.
- *MFA (Autenticação Multifator)*: Proteção adicional no controle de acesso.

- **Indicadores de Desempenho e Alertas:**

- *Indicadores*:
 - Tempo médio para detecção de incidentes.
 - Número de eventos anômalos detectados por mês.
 - Taxa de resolução de alertas críticos no SLA estabelecido.
- *Alertas*: Configuração de notificações em tempo real para eventos como:
 - Tentativas de acesso não autorizado.
 - Alterações inesperadas em configurações críticas.
 - Atividades fora do horário padrão de operação.

- **Uso do Framework COBIT:**

- Aplicação dos princípios do COBIT para garantir a governança de TI:
 - *Planejar e Organizar (PO)*: Estabelecer processos para identificar riscos e alinhar estratégias de TI aos objetivos da organização.
 - *Entregar e Suportar (DS)*: Implementação de mecanismos de controle e suporte contínuo.
 - *Monitorar e Avaliar (ME)*: Avaliação periódica da performance e aderência aos padrões.

Preparação para Auditoria

- **Criação de um Manual de Auditoria Interna:**
 - Documentação dos critérios principais:
 - Conformidade com a ABNT NBR ISO/IEC 27001.
 - Checklist das políticas de segurança implementadas.
 - Práticas de gestão de riscos e monitoramento contínuo.
- **Execução de Auditorias Internas Periódicas:**
 - Pontos a serem verificados:
 - Configurações de segurança dos sistemas.
 - Procedimentos de backup e recuperação de desastres.
 - Gestão de acessos e permissões.
 - Frequência recomendada: Trimestral.
- **Testes de Vulnerabilidades:**
 - *Pentests*: Simulação de ataques para identificar pontos fracos.
 - *Scan de Vulnerabilidades*: Identificação de falhas técnicas.
 - *Teste de Engenharia Social*: Avaliação da conscientização dos colaboradores em relação à segurança.

Proposta de Controles de Segurança

- **Controles Baseados na ABNT NBR ISO/IEC 27001:**
 - *Criptografia*: Proteção de dados sensíveis durante armazenamento e transmissão.
 - *Segurança Física*: Restrição de acesso a servidores e equipamentos críticos.
 - *Proteção de Dados Pessoais (LGPD)*: Implementação de controles para tratamento, armazenamento e descarte de dados pessoais.
- **Políticas e Procedimentos:**
 - *Gerenciamento de Riscos*: Avaliação contínua dos riscos associados aos ativos de TI.

- *Conformidade*: Garantir alinhamento com regulamentações específicas do setor.
- *Governança de TI*: Estabelecimento de um comitê para revisar práticas e estratégias.

Monitoramento e Avaliação Contínua

- **Plano de Monitoramento Contínuo:**
 - Utilização do ciclo PDCA:
 - *Plan*: Identificação de gaps e planejamento de melhorias.
 - *Do*: Implementação de controles de segurança.
 - *Check*: Avaliação contínua com base nos KPIs definidos.
 - *Act*: Adoção de ações corretivas e ajustes nas estratégias.

Preparação para Auditorias Externas

- **Documentações Necessárias:**
 - Relatórios de conformidade com ISO/IEC 27001.
 - Logs de auditoria e monitoramento contínuo.
 - Políticas e procedimentos de segurança implementados.
- **Relatórios Importantes:**
 - Análise de vulnerabilidades corrigidas nos últimos 12 meses.
 - Revisões de segurança de processos críticos.
 - Resultados de auditorias internas e ações de melhoria implementadas.